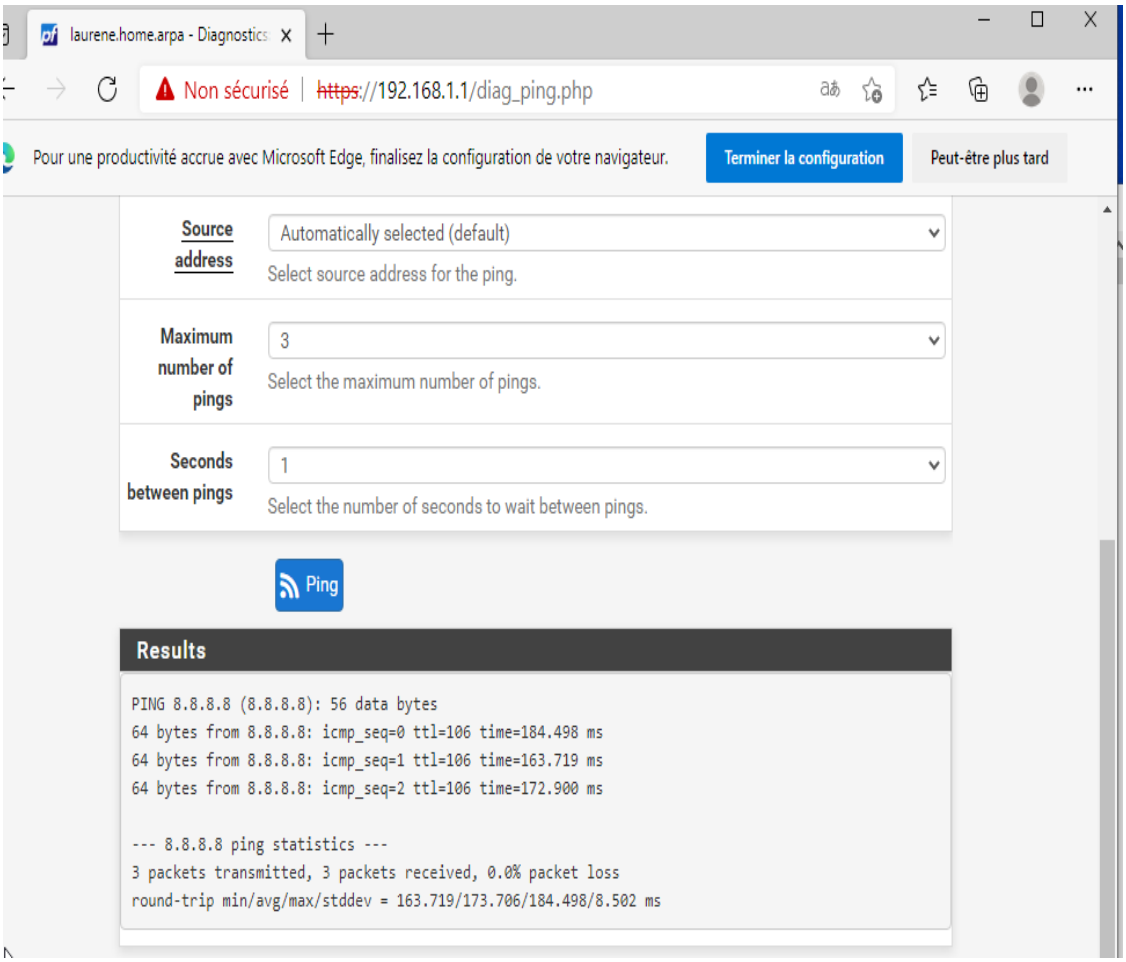
COMPTE-RENDU : TP 4.2 – DÉTECTION D'ATTAQUES AVEC SURICATA SUR PFSENSE

I. ÉLÉMENTS TECHNIQUES

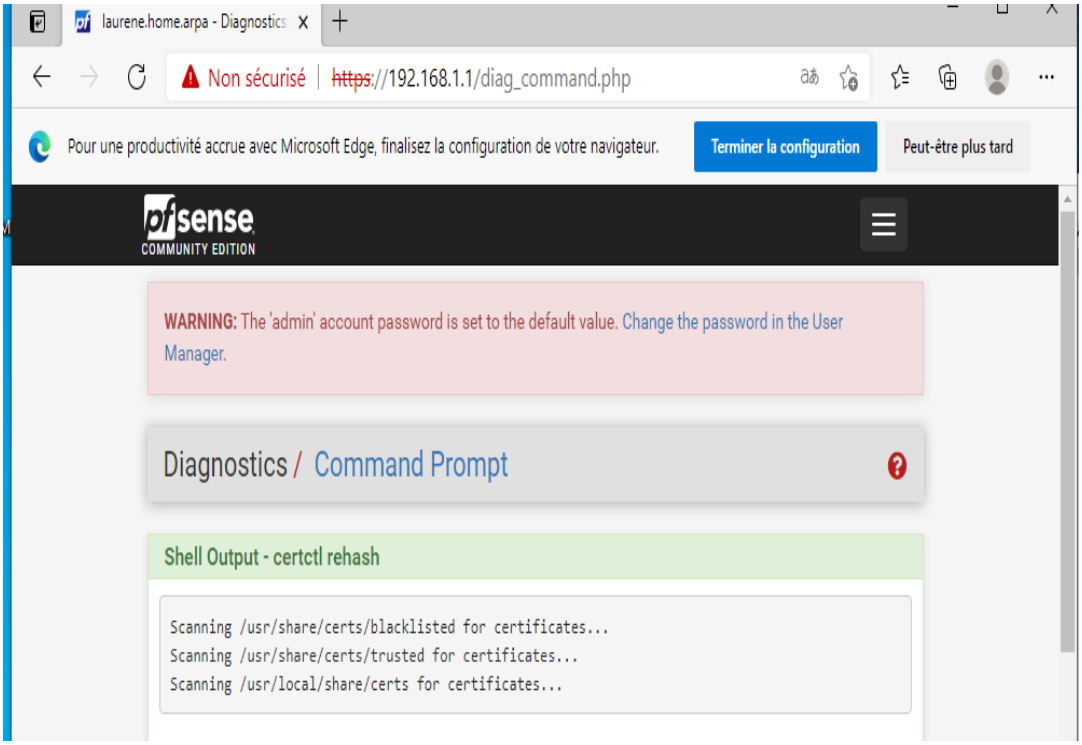
1. L'installation de Suricata

L'installation s'effectue via le gestionnaire de paquets de pfSense. Une fois le paquet ajouté, Suricata est configuré pour écouter sur l'interface LAN afin de surveiller le trafic interne.

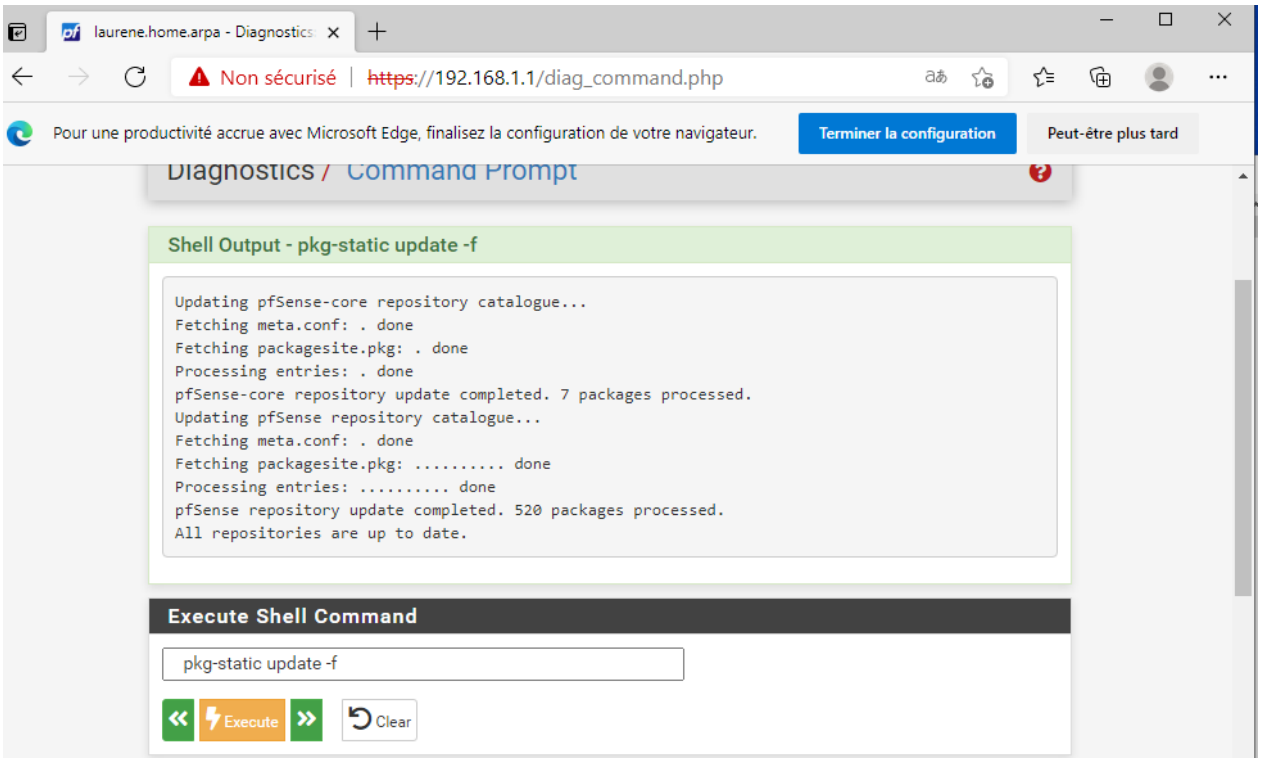
Test du ping sur 8.8.8



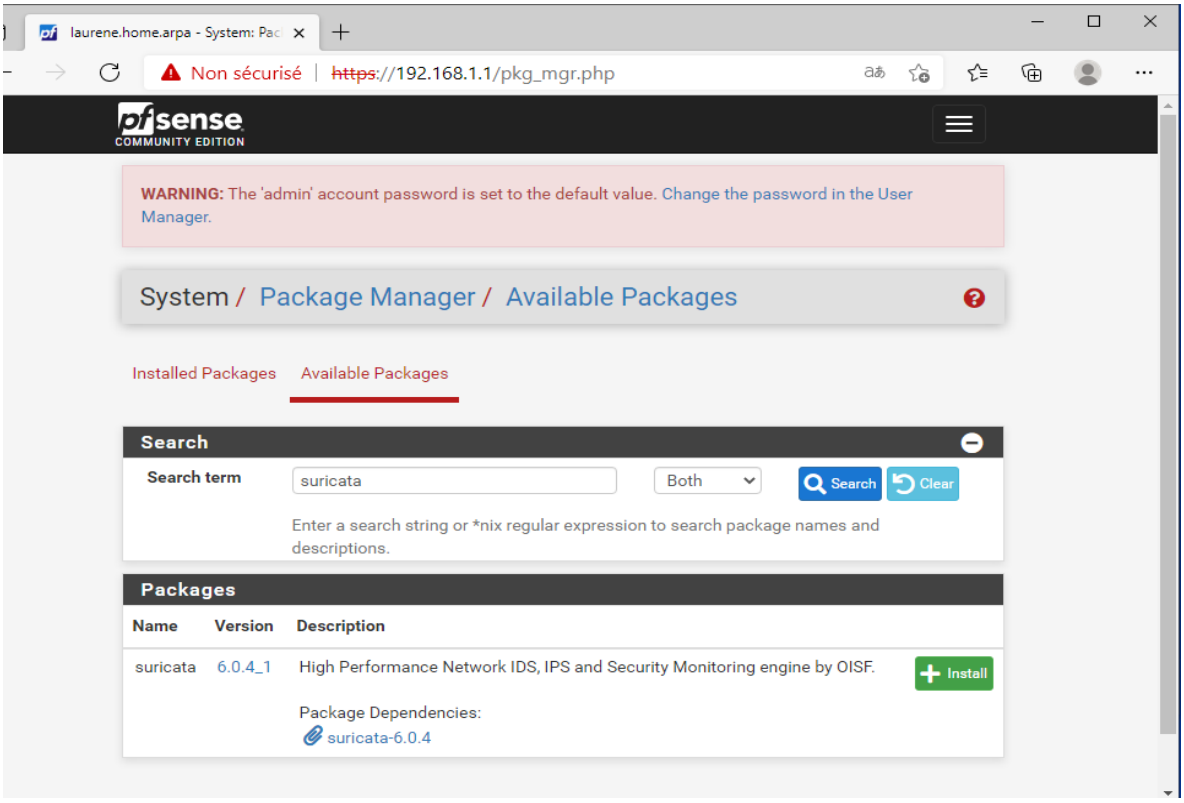
Commande pour rafraichir les certificats certctl rehash



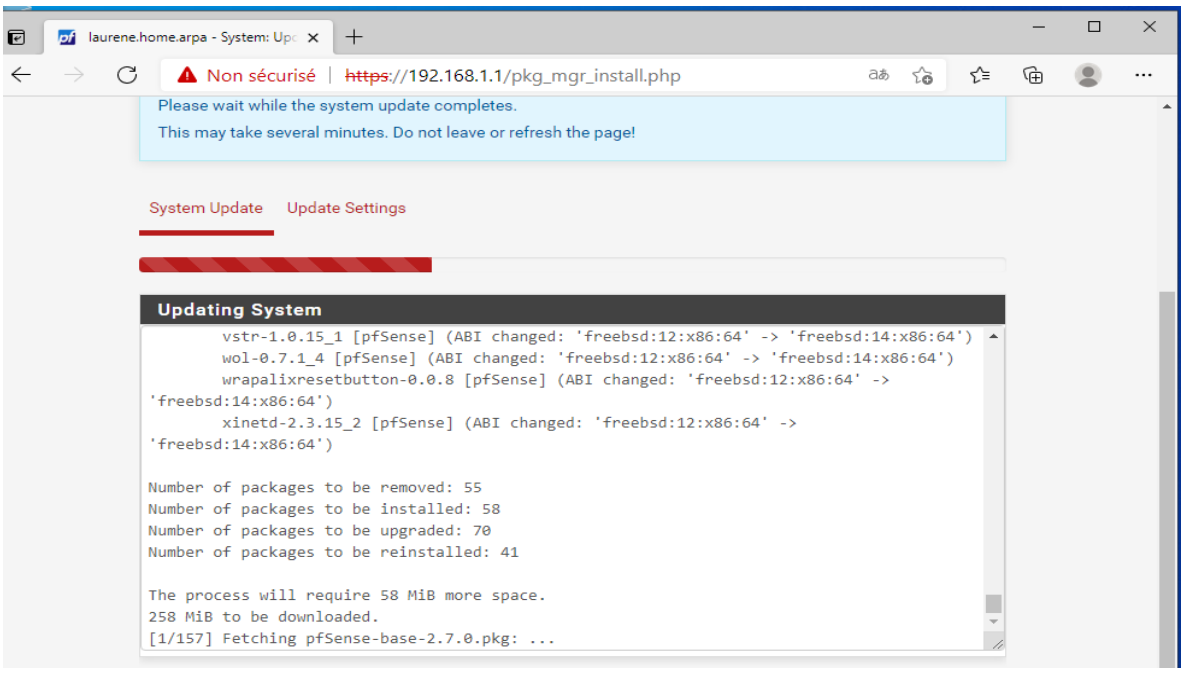
Commande pour forcer la mise à jour du gestionnaire de paquets : pkg-static update-f

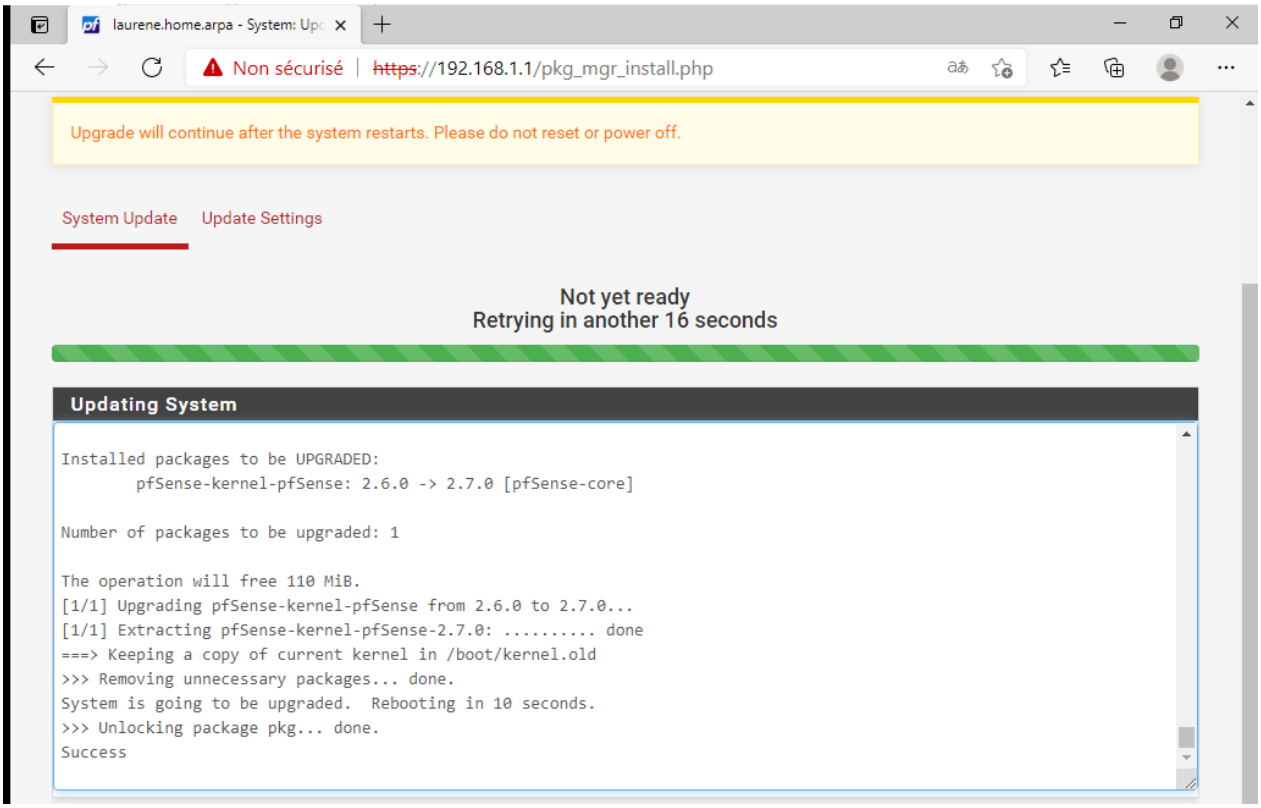


Installation de suricata sur via linterface pfsense

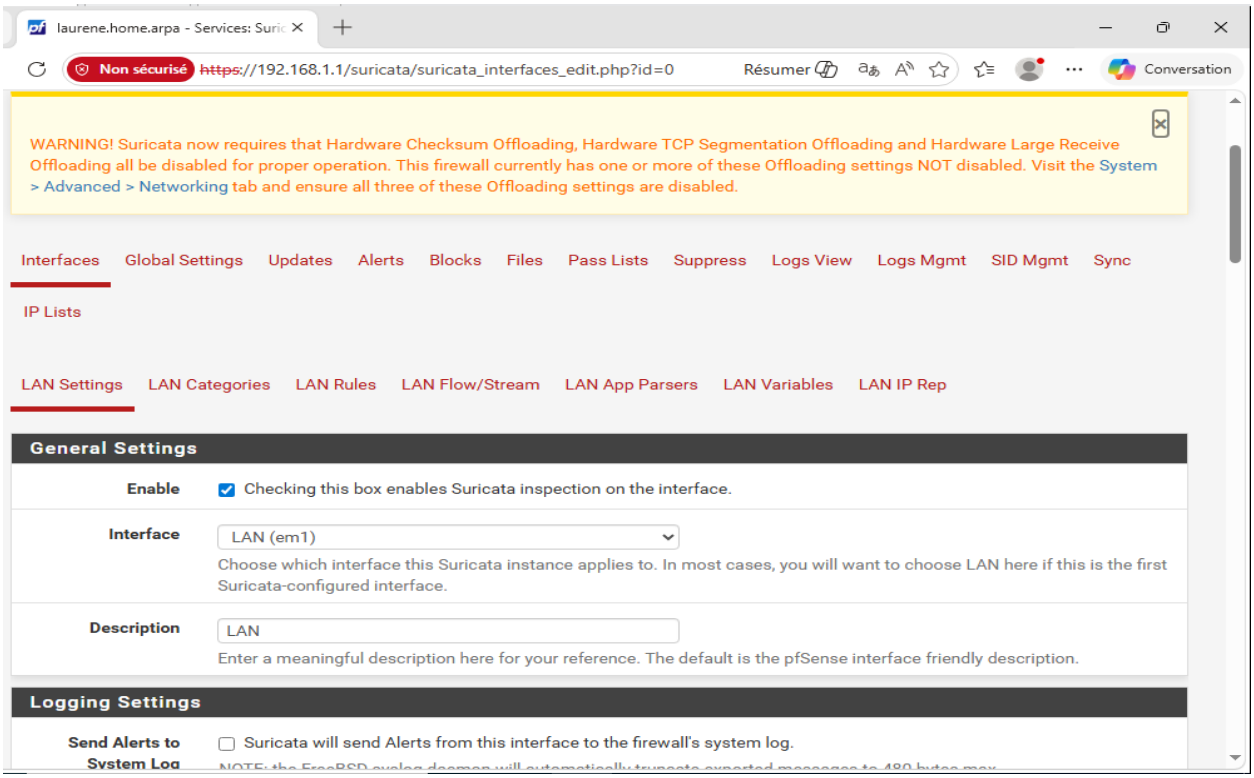


Mise à jour





Activation de suricata sur l'interface LAN

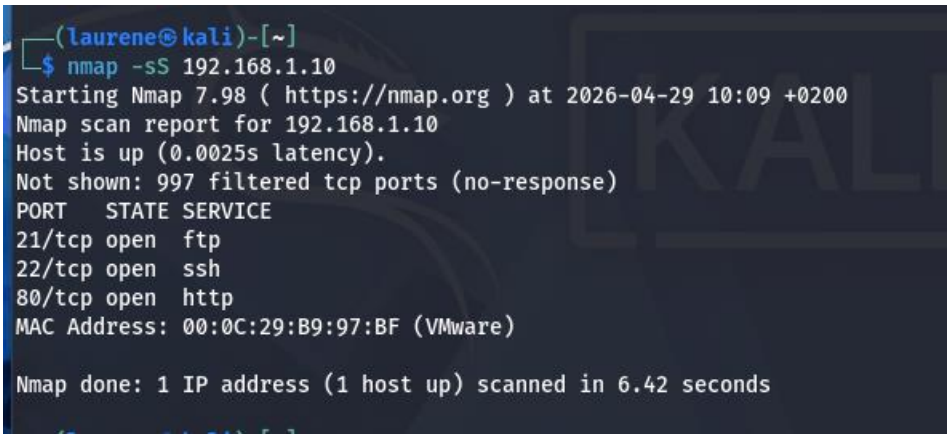


2. L'activation des règles

Pour que l'IDS soit efficace, nous avons activé les signatures (notamment Emerging Threats). Sans ces règles, l'outil ne peut pas identifier les motifs (patterns) des attaques.

3. Les alertes générées

Lorsqu'un trafic suspect correspond à une signature, Suricata consigne l'événement. L'alerte contient l'IP source, l'IP destination, et la nature de la menace. Depuis ma machine kali, je lance un scan nmap avec ubuntu : nmap –sS 192.168.1.10

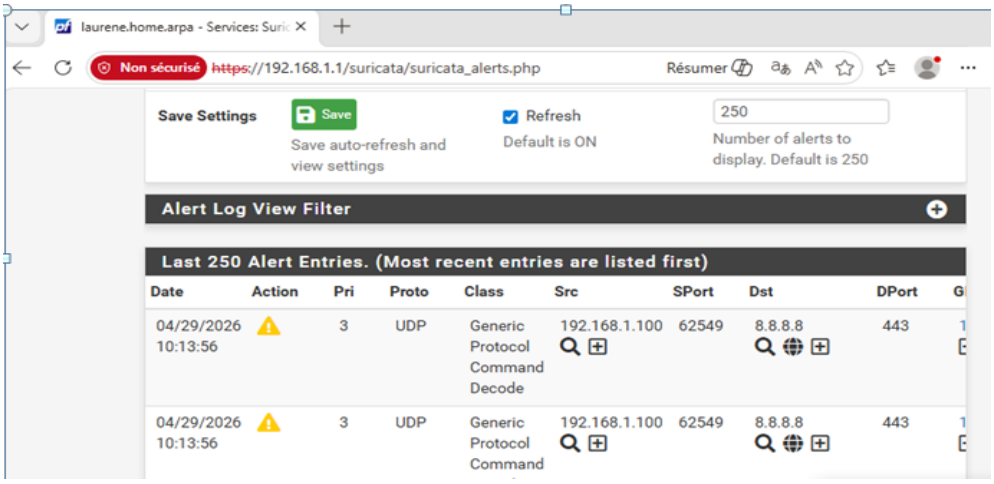


```
┌──(laurene㉿kali)-[~]
└─$ nmap -sS 192.168.1.10
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-29 10:09 +0200
Nmap scan report for 192.168.1.10
Host is up (0.0025s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT   STATE SERVICE
21/tcp open  ftp
22/tcp open  ssh
80/tcp open  http
MAC Address: 00:0C:29:B9:97:BF (VMware)

Nmap done: 1 IP address (1 host up) scanned in 6.42 seconds
```

4. Analyse des alertes

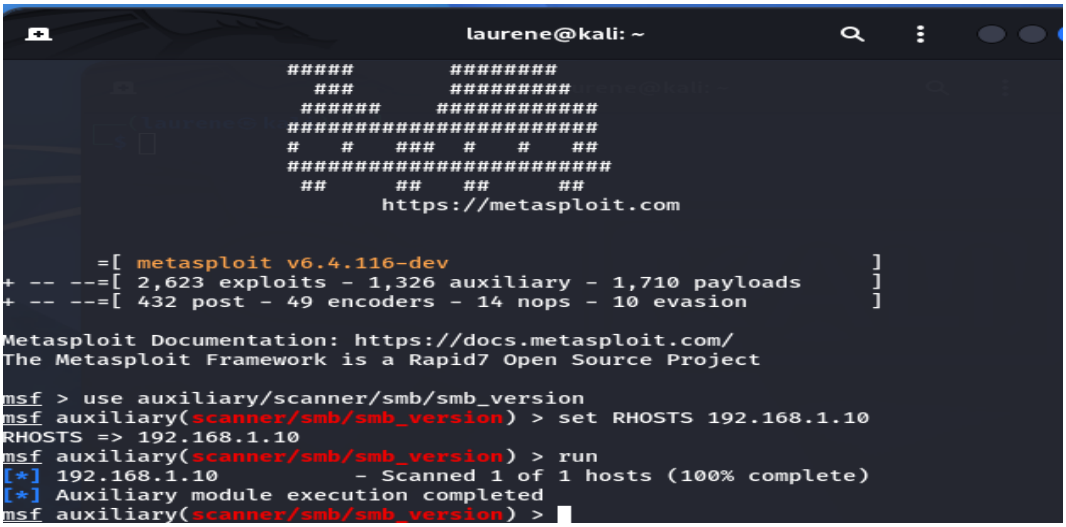
On retourne dans linterface web de pfsense on entre dans service puis dans suricata et on clic alerte :



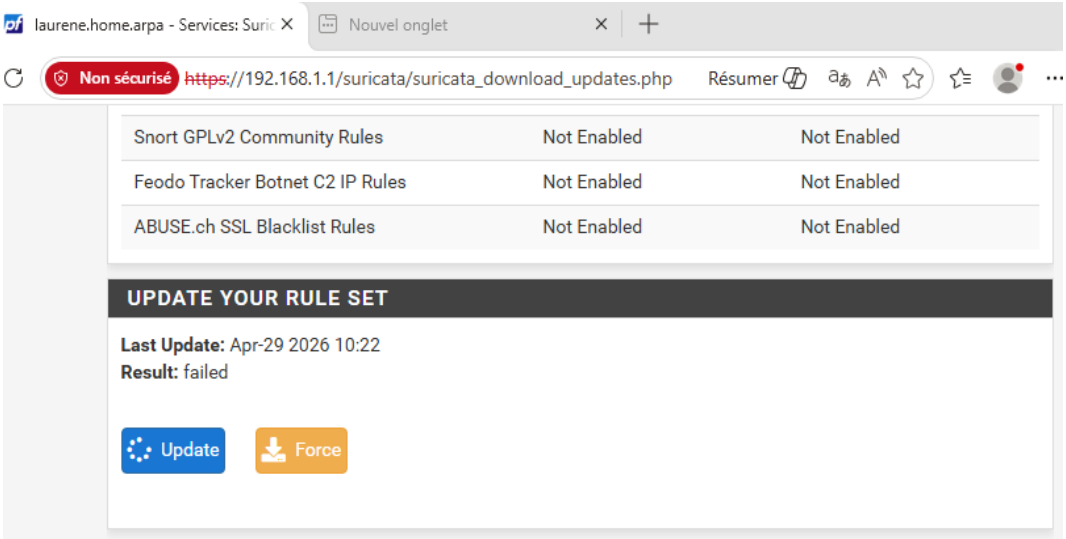
Simulation d'une attaque plus avancée

Nous avons aussi lancé un tes d'attaque via kali linux par la commande msfconsole afin de lancer une tentative d'exploitation avec la commande :

- **use auxiliary/scanner/smb/smb_version**
- **RHOSTS 192.168.1.10-**
- **run**

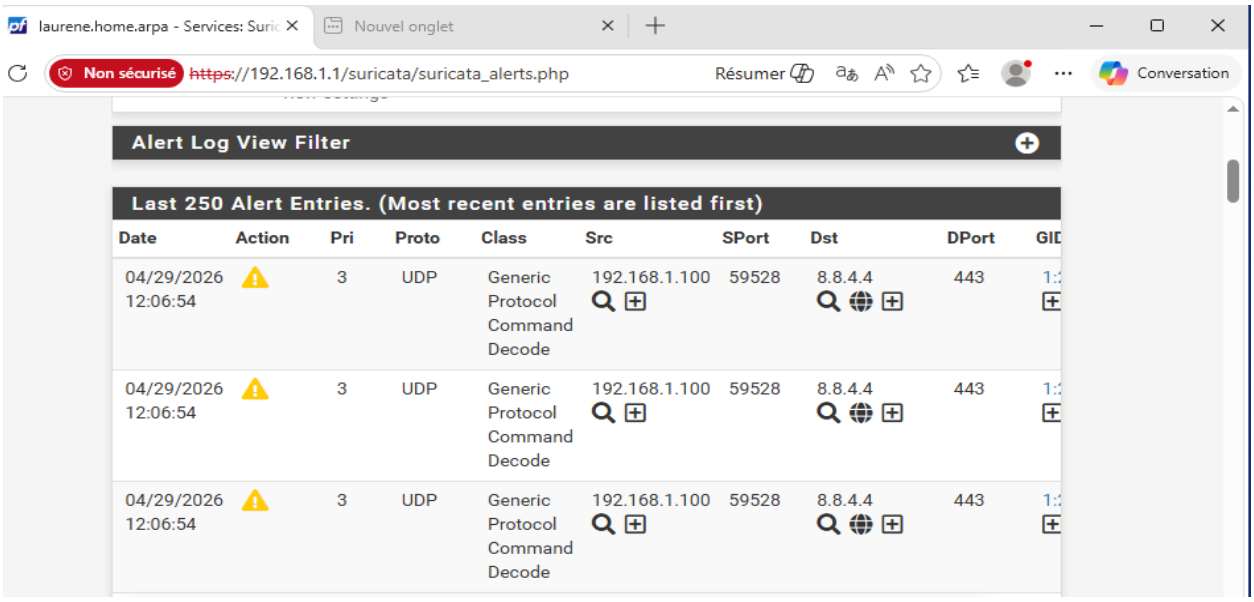


L'update ne prend pas



Détections de suricata des différentes tentatives d'exploitation effectuées

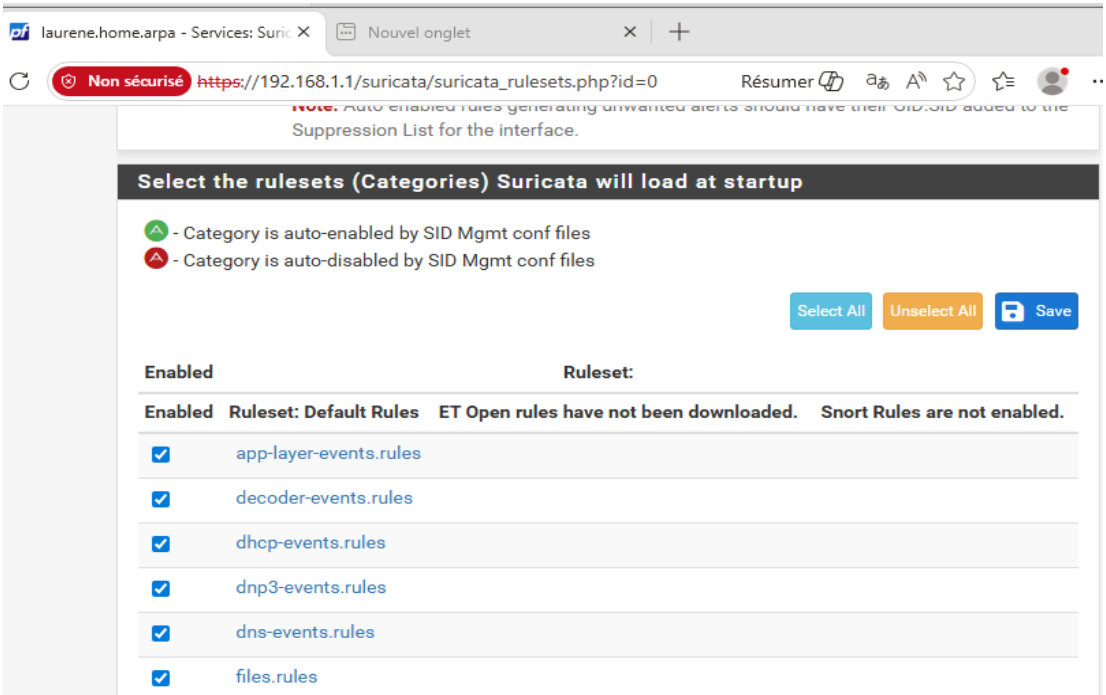
Ce résultat est dû au fait que l’update n’as pris. Si non sur dport on devait voir les ports de smb



5. Les tests d'attaque

Nous avons utilisé Kali Linux pour générer du trafic malveillant (Scan Nmap et tentative d'exploitation via Metasploit) afin de vérifier la réactivité du système.

Passage en mode blocage (ips)



II. EXPLICATIONS THÉORIQUES

Comment Suricata détecte une attaque :

Suricata utilise l'inspection profonde de paquets (DPI). Il analyse non seulement les en-têtes (IP, Ports) mais aussi le contenu (payload) des paquets. Il compare ces données à une base de signatures connues. S'il y a correspondance (matching), une alerte est déclenchée.

La différence entre IDS et IPS :

IDS (Intrusion Detection System) : Il est passif. Il surveille, détecte et alerte l'administrateur, mais laisse passer le trafic.

IPS (Intrusion Prevention System) : Il est actif. En plus de détecter, il bloque automatiquement le trafic jugé malveillant (mode "Drop" ou "Block Offenders").

L'intérêt des signatures :

Les signatures sont comme des "empreintes digitales" d'attaques connues. Elles permettent une détection rapide et précise des menaces courantes (scans, malwares, injections) sans nécessiter une analyse comportementale complexe qui pourrait ralentir le réseau.

III. OPTIONS AVANCÉES DE SURICATA

Types de règles :

On distingue les règles de Pass (autoriser), Alert (notifier sans bloquer) et Drop (rejeter le paquet en mode IPS).

Niveaux de sévérité :

Chaque alerte possède une priorité (Class Type). Cela permet à l'administrateur de filtrer les alertes critiques (Priority 1) des événements moins graves (Priority 3).

Filtrage des alertes (Suppress/Threshold) :

Cette option permet de limiter le "bruit" sur le réseau en évitant d'être inondé par des milliers d'alertes identiques pour un même événement, ou de supprimer les faux positifs (trafic légitime détecté par erreur).

IV. COMPÉTENCES ACQUISES

À l'issue de ce TP, je suis capable de :

- Surveiller un réseau en temps réel pour identifier les flux suspects.
- Détecter des comportements anormaux (scans de ports, tentatives d'intrusion).-
- Réagir face à une attaque en passant du mode détection (IDS) au mode protection active (IPS